คู่มือทางเทคนิคเชิงลึก

สถาปัตยกรรมความมั่นคงปลอดภัยไซเบอร์

การพัฒนา DevSecOps และการบูรณาการมาตรฐานภาครัฐ

Technical Architecture Manual for Cybersecurity,

DevSecOps & Government Standards Integration

ฉบับปี พ.ศ. 2568–2569 (2025–2026)

จัดทำตามมาตรฐาน OWASP Top 10 — 2025 Edition | NIST CSF 2.0 | ISO/IEC 27001:2022

ครอบคลุม: OWASP · NIST · ISO · DevSecOps · Zero Trust · Post-Quantum · AI Security · Data Sovereignty

บทนำ

ในยุคที่ปัญญาประดิษฐ์ (AI) กลายเป็นเครื่องมือหลักทั้งในฝั่งผู้พัฒนาและผู้โจมตี หน่วยงานภาครัฐจำเป็นต้องยกระดับกระบวนการพัฒนา ทดสอบ ติดตั้ง และดูแลระบบซอฟต์แวร์ทั้งหมด ให้สอดคล้องกับภัยคุกคามที่เปลี่ยนแปลงอย่างรวดเร็ว คู่มือฉบับนี้รวบรวมและเรียบเรียงเนื้อหาจากแหล่งอ้างอิงระดับสากล ได้แก่ OWASP Top 10 — 2025, OWASP ASVS v5.0, NIST CSF 2.0, ISO/IEC 27001:2022 และยุทธศาสตร์การสร้างอธิปไตยข้อมูลภาครัฐ

คู่มือนี้ถูกออกแบบให้เป็น "Practical Guide" — เน้นแนวปฏิบัติที่นำไปใช้ได้จริง พร้อม Use Cases, Checklists, Architecture Diagrams และ Solution Playbooks ที่เจาะลึกเพียงพอสำหรับทีมพัฒนา ทีมรักษาความปลอดภัย และผู้บริหารเทคโนโลยีสารสนเทศ ของหน่วยงานภาครัฐทุกระดับ ตั้งแต่กระทรวงกลาง สำนักงานเขต ไปจนถึงหน่วยงานส่วนท้องถิ่น

วัตถุประสงค์ของคู่มือ

คู่มือฉบับนี้มีวัตถุประสงค์หลัก 4 ประการ ดังนี้

- เพื่อให้บุคลากรภาครัฐเข้าใจสถาปัตยกรรมความมั่นคงปลอดภัยไซเบอร์ระดับองค์กรและนำไปประยุกต์ใช้ได้จริง
- เพื่อให้ทีมพัฒนาสามารถนำกระบวนการ DevSecOps มาฝังในวงจรการพัฒนาซอฟต์แวร์ได้อย่างครบวงจร
- เพื่อบูรณาการมาตรฐานสากล (OWASP, NIST, ISO) กับกฎหมายและข้อบังคับของประเทศไทย ได้แก่ พ.ร.บ.ไซเบอร์ฯ และ PDPA
- เพื่อให้หน่วยงานภาครัฐสามารถสร้างอธิปไตยข้อมูล (Data Sovereignty) และลดการพึ่งพาเทคโนโลยีต่างชาติ

ขอบเขตของคู่มือ

คู่มือฉบับนี้ครอบคลุมเนื้อหา 6 บทหลัก ดังนี้

- บทที่ 1: มาตรฐานและกรอบการทำงานด้านความปลอดภัยสากล (OWASP, NIST, ISO, CSA)
- บทที่ 2: โซลูชันเจาะลึก OWASP Top 10:2025 พร้อม Use Cases ภาครัฐ
- บทที่ 3: สถาปัตยกรรม DevSecOps และ CI/CD Pipeline ที่ปลอดภัย
- บทที่ 4: การตรวจสอบ การติดตาม และการรายงานผลตามมาตรฐานภาครัฐ
- บทที่ 5: ภัยคุกคามอุบัติใหม่ในยุค AI และการรับมือ
- บทที่ 6: อธิปไตยข้อมูลภาครัฐและระบบเอกสารดิจิทัลอัจฉริยะ

กลุ่มเป้าหมาย

คู่มือนี้จัดทำสำหรับบุคลากรหลายกลุ่ม ได้แก่ นักพัฒนาซอฟต์แวร์และ DevOps Engineer ที่ต้องการฝัง Security ไว้ในกระบวนการพัฒนา, Security Engineer และผู้เชี่ยวชาญด้านความปลอดภัย ที่ต้องการแนวทางเชิงสถาปัตยกรรม, IT Manager และ CISO ที่วางนโยบายความปลอดภัยระดับองค์กร รวมถึงผู้จัดทำ TOR/RFP ที่ต้องการกำหนด Security Requirements ที่ถูกต้องและครบถ้วน

สารบัญ

บทนำ

บทที่ 1 มาตรฐานและกรอบการทำงานด้านความปลอดภัยสากล

1.1 ภาพรวม OWASP และโครงการสำคัญ

1.2 NIST Cybersecurity Framework 2.0

1.3 ISO/IEC 27001:2022 และ CSA STAR

1.4 กำหนดการทดสอบความปลอดภัย (Pentest Schedule)

1.5 Disaster Recovery & Business Continuity

บทที่ 2 โซลูชันเจาะลึก OWASP Top 10:2025

2.1 A01 — Broken Access Control

2.2 A02 — Cryptographic Failures

2.3 A03 — Injection

2.4 A04 — Insecure Design

2.5 A05 — Security Misconfiguration

2.6 A06 — Software Supply Chain Failures

2.7 A07 — Authentication Failures

2.8 A08 — Software & Data Integrity Failures

2.9 A09 — Security Logging & Monitoring Failures

2.10 A10 — Mishandling of Exceptional Conditions

บทที่ 3 สถาปัตยกรรม DevSecOps และ CI/CD Pipeline ที่ปลอดภัย

3.1 หลักการ DevSecOps และ Shift-Left Security

3.2 CI/CD Pipeline Security — SAST, DAST, SCA

3.3 Container Security และ Kubernetes Hardening

3.4 Infrastructure as Code (IaC) Security

3.5 Secret Management และ Zero Trust Architecture

บทที่ 4 การตรวจสอบ การติดตาม และการรายงานผล

4.1 Vulnerability Assessment & Penetration Testing

4.2 ASVS v5.0 Verification Playbook

4.3 ระบบรายงานภาครัฐ — แบบฟอร์ม ค๑/ค๒

4.4 Incident Response ตาม NIST SP 800-61 Rev.3

บทที่ 5 ภัยคุกคามอุบัติใหม่ในยุค AI และการรับมือ

5.1 Agentic AI & Automated Attacks

5.2 AI-driven Threat Detection — SIEM/SOAR/XDR

5.3 Post-Quantum Cryptography — Migration Playbook

5.4 LLM Security — OWASP Top 10 for LLM 2025

5.5 MLSecOps Pipeline

บทที่ 6 อธิปไตยข้อมูลภาครัฐและระบบเอกสารดิจิทัล

6.1 Data Sovereignty Framework ของไทย

6.2 Collabora Online — Server-Side Rendering Architecture

6.3 ONLYOFFICE DocSpace — HTML5 Canvas Architecture

6.4 Federated Cloud สำหรับภาครัฐ

6.5 Government-Grade Security สำหรับเอกสารดิจิทัล

บทสรุป

บทที่ 1

มาตรฐานและกรอบการทำงานด้านความปลอดภัยสากล

มาตรฐานและกรอบการทำงาน (Frameworks) ด้านความปลอดภัยไซเบอร์คือรากฐานของการพัฒนาระบบ ที่ปลอดภัย ก่อนที่หน่วยงานภาครัฐจะสามารถวางนโยบาย กำหนด TOR/RFP หรือตรวจสอบความปลอดภัยได้อย่างมีประสิทธิภาพ จำเป็นต้องเข้าใจมาตรฐานเหล่านี้อย่างถ่องแท้ บทนี้รวบรวมมาตรฐานที่สำคัญที่สุด 4 กลุ่ม ได้แก่ OWASP, NIST, ISO/IEC และ CSA

1.1 ภาพรวม OWASP และโครงการสำคัญ

OWASP (Open Web Application Security Project) เป็นโครงการไม่แสวงหาผลกำไรระดับสากล ที่มุ่งพัฒนาความปลอดภัยของซอฟต์แวร์ โดยจัดทำเครื่องมือ มาตรฐาน และแนวปฏิบัติ ที่ครอบคลุมวงจรชีวิตการพัฒนาซอฟต์แวร์ทั้งหมด ตั้งแต่ขั้นตอนการออกแบบ พัฒนา ทดสอบ จนถึงการดูแลรักษา โครงการของ OWASP ทั้งหมดเป็นสาธารณะและใช้งานได้ฟรี

โครงการ	วัตถุประสงค์	การนำไปใช้ในภาครัฐ
OWASP Top 10 (Web)	ระบุช่องโหว่เว็บแอปพลิเคชัน 10 อันดับแรก	เกณฑ์ขั้นต่ำสำหรับ Pentest ก่อน Go-live
OWASP ASVS v5.0	มาตรฐานตรวจสอบความปลอดภัย 350 ข้อ 17 หมวด	กำหนด Security Requirements ใน TOR/RFP
OWASP Top 10 for LLM 2025	ช่องโหว่เฉพาะ Large Language Models	Guardrails สำหรับ AI Chatbot ภาครัฐ
OWASP SAMM	วัดระดับวุฒิภาวะด้าน Software Security	Roadmap การยกระดับ DevSecOps
OWASP Testing Guide	คู่มือทดสอบความปลอดภัยเว็บแอปพลิเคชัน	กรอบการทำ Pentest สำหรับผู้ตรวจสอบ

เปรียบเทียบ ASVS v4.0.3 กับ ASVS v5.0

OWASP เปิดตัว ASVS Version 5.0.0 อย่างเป็นทางการเมื่อวันที่ 30 พฤษภาคม 2568 ที่งาน Global AppSec EU Barcelona ถือเป็นการปรับปรุงครั้งใหญ่ที่สุดในประวัติศาสตร์ มาตรฐานประกอบด้วยข้อกำหนดกว่า 350 ข้อ ใน 17 หมวดหมู่

เปรียบเทียบ	ASVS v4.0.3	ASVS v5.0
จำนวนข้อกำหนด	286 ข้อ	350 ข้อ
จำนวนหมวดหมู่	14 บท	17 บท (ปรับโครงสร้างใหม่)
Level 1	131 ข้อ (Barrier สูงเกินไป)	เบาลงเพื่อลด Barrier to Entry
Black-box Testing	คลุมเครือว่า L1 ใช้ได้หรือไม่	ระบุชัดว่าไม่เพียงพอทุก Level

Requirement Style	Technical Prescriptions	Goal-Oriented — เน้น Security Outcomes

1.2 NIST Cybersecurity Framework 2.0

NIST Cybersecurity Framework (CSF) 2.0 เป็นกรอบการจัดการความเสี่ยงไซเบอร์แบบครบวงจรที่เผยแพร่โดย National Institute of Standards and Technology ในเดือนกุมภาพันธ์ 2567 ประกอบด้วย 6 ฟังก์ชันหลักที่สอดคล้องกัน เหมาะสำหรับใช้เป็น Baseline ของนโยบายความปลอดภัยระดับองค์กรและใช้อ้างอิงใน TOR/RFP ของภาครัฐ

ฟังก์ชัน	คำอธิบาย	ตัวอย่างการนำไปใช้
Govern (ใหม่)	กำหนดนโยบายและกำกับดูแล Cybersecurity Risk	จัดทำนโยบาย ISMS ระดับองค์กร
Identify	ระบุ Asset, Risk และช่องโหว่	ทำ Asset Inventory และ Risk Assessment ประจำปี
Protect	ปกป้อง Asset ด้วย Safeguards	MFA, Encryption, Access Control, Patching
Detect	ตรวจจับเหตุการณ์ผิดปกติ	SIEM, IDS/IPS, Log Monitoring
Respond	ตอบสนองต่อเหตุการณ์	Incident Response Plan, Playbooks
Recover	กู้คืนระบบหลังเหตุการณ์	BCP/DRP, Backup Testing, Post-Incident Review

1.3 ISO/IEC 27001:2022 และ CSA STAR

ISO/IEC 27001:2022

ISO/IEC 27001:2022 เป็นมาตรฐานระบบบริหารจัดการความมั่นคงปลอดภัยสารสนเทศ (ISMS) ที่ได้รับการยอมรับระดับสากล เวอร์ชัน 2022 ได้ปรับโครงสร้าง Annex A ใหม่ โดยจัดกลุ่ม Controls เป็น 4 หมวดหลัก ได้แก่ Organizational Controls (37 ข้อ), People Controls (8 ข้อ), Physical Controls (14 ข้อ) และ Technological Controls (34 ข้อ) หน่วยงานภาครัฐควรพิจารณาขอรับรองมาตรฐานนี้สำหรับระบบสำคัญ

- แนะนำให้หน่วยงานที่มีบุคลากรด้าน IT เกิน 20 คนดำเนินการขอรับรอง
- ระยะเวลาดำเนินการขอรับรองครั้งแรกประมาณ 12–18 เดือน
- ค่าใช้จ่ายในการตรวจรับรองขึ้นอยู่กับขนาดองค์กรและ Body of Certification ที่เลือก

CSA STAR (Cloud Security Alliance)

CSA STAR เป็นกรอบการประเมินความปลอดภัยคลาวด์ที่ใช้ Cloud Controls Matrix (CCM) และ Consensus Assessment Initiative Questionnaire (CAIQ) เหมาะสำหรับประเมินผู้ให้บริการคลาวด์ก่อนการจัดซื้อ โดยมี 3 ระดับ ได้แก่ Level 1 (Self-Assessment), Level 2 (3rd-party Audit) และ Level 3 (Continuous Monitoring)

1.4 กำหนดการทดสอบความปลอดภัย

การทดสอบความปลอดภัยต้องดำเนินการอย่างสม่ำเสมอและครอบคลุมทุกขั้นตอนของวงจรชีวิตระบบ ตารางต่อไปนี้เป็นแนวทางที่แนะนำสำหรับหน่วยงานภาครัฐ

เหตุการณ์	ประเภทการทดสอบ	ความถี่
ก่อนเปิดใช้ระบบ (Pre-launch)	Full Pentest (Grey/White Box)	ครั้งเดียวก่อน Go-live
เปลี่ยนแปลงฟีเจอร์หลัก	Targeted Pentest + Regression	ทุกครั้งที่มี Major Release
ระบบปกติ (BAU)	VA Scan อัตโนมัติ	รายสัปดาห์/รายเดือน
การประเมินรายปี	Full Pentest + Compliance Check	อย่างน้อยปีละ 1 ครั้ง
หลังเกิด Incident	Root Cause Analysis + Re-pentest	ทุกครั้งที่มีเหตุการณ์ร้ายแรง

1.5 Disaster Recovery & Business Continuity

การวางแผน Business Continuity (BCP) และ Disaster Recovery (DRP) เป็นข้อกำหนดบังคับสำหรับหน่วยงานภาครัฐ โดยเฉพาะหน่วยงาน Critical Information Infrastructure (CII) ตาม พ.ร.บ.การรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562 องค์กรต้องจัดทำ Business Impact Analysis (BIA) เพื่อกำหนด RTO และ RPO ตามความทนทานจริง

ระดับบริการ	RTO เป้าหมาย	RPO เป้าหมาย	กลยุทธ์กู้คืน
Mission-Critical (ระบบชำระเงิน/ทะเบียนราษฎร์)	< 1 ชั่วโมง	< 15 นาที	Active-Active, Real-time Replication
Business-Critical (เว็บไซต์หลัก/พอร์ทัลบริการ)	< 4 ชั่วโมง	< 1 ชั่วโมง	Warm Standby, Hourly Backup
Standard (ระบบสนับสนุน/อีเมล)	< 24 ชั่วโมง	< 4 ชั่วโมง	Cold Standby, Daily Backup
Low Priority (ระบบทดสอบ/Training)	< 72 ชั่วโมง	< 24 ชั่วโมง	Backup & Restore from Archive

บทที่ 2

โซลูชันเจาะลึก OWASP Top 10:2025

OWASP Top 10:2025 ได้รับการปรับปรุงเพื่อสะท้อนภัยคุกคามยุค AI และสถาปัตยกรรม Microservices โดยมีการเพิ่มหมวดหมู่ใหม่ 2 รายการและรวม SSRF เข้าใน Broken Access Control บทนี้เจาะลึกแต่ละข้อพร้อม Use Cases สำหรับหน่วยงานภาครัฐไทย

2.1 A01 — Broken Access Control (รวม SSRF)

ช่องโหว่ด้านการควบคุมการเข้าถึงยังคงเป็นอันดับ 1 ต่อเนื่อง โดย 100% ของแอปพลิเคชันที่ทดสอบพบช่องโหว่ในหมวดนี้ ครอบคลุม IDOR, Path Traversal, Missing Function Level Access Control, CORS Misconfiguration และ SSRF ใน Microservices Architecture

Use Case: ระบบสวัสดิการภาครัฐ

สถานการณ์: ระบบจ่ายสวัสดิการออนไลน์ที่เจ้าหน้าที่สามารถดูข้อมูลผู้รับสวัสดิการ โดยเปลี่ยน ID ใน URL (/api/beneficiary/12345) เพื่อเข้าถึงข้อมูลของผู้อื่น (IDOR)

แนวทางแก้ไข

- ใช้ Attribute-Based Access Control (ABAC): ตรวจสอบว่าผู้ใช้มีสิทธิ์เข้าถึงข้อมูลเฉพาะรายการที่ตนรับผิดชอบ
- เปลี่ยนจาก Sequential ID เป็น UUID v4 เพื่อป้องกัน Enumeration Attack
- ใช้ Server-Side Authorization Check ทุก Endpoint — ห้ามพึ่ง Client-Side เพียงอย่างเดียว
- บันทึก Access Log ทุกครั้งที่มีการเข้าถึงข้อมูลส่วนบุคคล เพื่อ Audit Trail ตาม PDPA
- ป้องกัน SSRF ด้วย Network Allowlist — จำกัด Outbound Requests ให้เฉพาะ Domain ที่อนุญาต

ตัวอย่าง ABAC Check (Python Flask)

```
# Server-Side ABAC Check — Deny by Default
@app.route("/api/beneficiary/<uuid:bid>", methods=["GET"])
@login_required
def get_beneficiary(bid):
    user = get_current_user()
    beneficiary = Beneficiary.query.get_or_404(bid)
    # ตรวจสอบสิทธิ์เข้าถึงระดับ Record
    if not user.has_permission("read", beneficiary):
        audit_log(user, "UNAUTHORIZED_ACCESS_ATTEMPT", bid)
        abort(403)  # Forbidden
    audit_log(user, "READ", bid)
    return jsonify(beneficiary.to_safe_dict())
```

2.2 A02 — Cryptographic Failures

ครอบคลุมการใช้ Algorithm ที่ล้าสมัย (MD5, SHA-1, DES), การจัดเก็บ Key ไม่ปลอดภัย, Missing Encryption at Rest/Transit และ Certificate Mismanagement การเข้ารหัสที่ไม่ถูกต้องเปิดให้ข้อมูลส่วนบุคคลและข้อมูลความมั่นคงของชาติถูกเปิดเผยได้

Use Case: ระบบทะเบียนราษฎร์

สถานการณ์: ฐานข้อมูลทะเบียนราษฎร์ใช้ MD5 hash สำหรับเลขบัตรประชาชน และส่งข้อมูลระหว่าง Microservices ผ่าน HTTP ภายใน Internal Network โดยไม่เข้ารหัส

แนวทางแก้ไข

- เปลี่ยนจาก MD5 เป็น Argon2id สำหรับ Password Hashing และ AES-256-GCM สำหรับ Encryption at Rest
- บังคับ mTLS (Mutual TLS) สำหรับ Service-to-Service Communication แม้ใน Internal Network
- ใช้ Hardware Security Module (HSM) หรือ Cloud KMS สำหรับ Key Management — ห้ามเก็บ Key ใน Source Code
- ตั้ง Automated Certificate Rotation ด้วย cert-manager (Kubernetes) หรือ HashiCorp Vault PKI
- เตรียม Migration สู่ Post-Quantum Cryptography (ML-KEM, ML-DSA) สำหรับข้อมูลที่มีอายุยาว

2.3 A03 — Injection

ครอบคลุม SQL Injection, XSS, Command Injection, LDAP Injection, NoSQL Injection และ Prompt Injection สำหรับ LLM โดย Injection ยังคงเป็นหนึ่งในช่องโหว่ที่พบบ่อยที่สุดในระบบราชการที่พัฒนาด้วยระบบเก่า (Legacy System)

แนวทางแก้ไขหลัก

- ใช้ Parameterized Queries / Prepared Statements เท่านั้น — ห้ามต่อ String ด้วยการ Concatenation
- ใช้ ORM ที่ได้รับการยอมรับ เช่น SQLAlchemy, Hibernate, Entity Framework, Prisma
- ติดตั้ง WAF (Web Application Firewall) พร้อม OWASP Core Rule Set v4
- ใช้ Content Security Policy (CSP) Header เพื่อป้องกัน Stored/Reflected XSS
- ทำ Input Validation แบบ Allowlist (Whitelist) Approach ทุก Input Field

ตัวอย่าง Parameterized Query (Python)

```
# WRONG — SQL Injection Risk
query = f"SELECT * FROM citizens WHERE id = '{user_input}'"

# CORRECT — Parameterized Query
result = db.session.execute(
    text("SELECT * FROM citizens WHERE id = :citizen_id"),
    {"citizen_id": user_input}
)
```

2.4 A04 — Insecure Design

ช่องโหว่จากการออกแบบที่ไม่ปลอดภัยตั้งแต่ต้น ไม่สามารถแก้ได้ด้วยการเขียนโค้ดที่ สมบูรณ์แบบ ต้องแก้ที่ระดับสถาปัตยกรรมเท่านั้น ถือเป็นปัญหาที่ต้องลงทุนป้องกัน ตั้งแต่ขั้นตอนออกแบบระบบ

- ทำ Threat Modeling ด้วย STRIDE/PASTA/LINDDUN ทุกโครงการก่อนเริ่มพัฒนา
- กำหนด Security Requirements ใน TOR/RFP ตามข้อกำหนด ASVS v5.0 ระดับ L2
- ใช้ Secure Design Patterns: Defense in Depth, Least Privilege, Fail-Safe Defaults
- จัดทำ Abuse Case Testing ควบคู่กับ Use Case Testing ในขั้นตอน QA
- กำหนด Security Architecture Review Board ให้ตรวจสอบ Design ก่อน Development

2.5 A05 — Security Misconfiguration

Security Misconfiguration เป็นช่องโหว่ที่เกิดจากการตั้งค่าระบบ Server, Framework, Database หรือ Cloud Services ที่ไม่ปลอดภัย รวมถึงการไม่ปิด Default Credentials และ Debug Endpoints

- ใช้ Infrastructure as Code (IaC) เช่น Terraform, Ansible พร้อม Security Linting (Checkov, tfsec)
- สแกน Configuration ด้วย CIS Benchmarks อัตโนมัติในทุก Environment
- ปิด Default Credentials, Debug Endpoints, Directory Listing ทันทีหลัง Deploy
- ใช้ Hardened Container Images (Distroless หรือ Alpine-based)
- ตั้ง Security Headers ทุกตัว: HSTS, X-Content-Type-Options, X-Frame-Options, CSP, Permissions-Policy

2.6 A06 — Software Supply Chain Failures

ขยายขอบเขตจาก "Vulnerable and Outdated Components" ครอบคลุม Supply Chain Attack, Typosquatting, Dependency Confusion และ Compromised Build Pipelines ซึ่งเป็นภัยคุกคามที่เพิ่มขึ้นอย่างรวดเร็วในปี 2025–2026

- ใช้ Software Composition Analysis (SCA) เช่น Snyk, OWASP Dependency-Check ใน CI/CD Pipeline
- จัดทำ Software Bill of Materials (SBOM) ตามรูปแบบ CycloneDX หรือ SPDX ทุก Release
- ตั้ง Automated Dependency Update ด้วย Dependabot หรือ Renovate Bot
- กำหนด SLA การแก้ไข: Critical < 48 ชม., High < 7 วัน, Medium < 30 วัน
- ตรวจสอบ Integrity ของ CI/CD Pipeline ด้วย SLSA Framework (Supply chain Levels for Software Artifacts)

2.7 A07 — Authentication Failures

ครอบคลุมปัญหาการพิสูจน์ตัวตน ทั้ง Brute Force, Credential Stuffing, Session Fixation, Insecure Password Storage และ Missing MFA โดยเฉพาะ ในระบบที่ให้บริการประชาชนจำนวนมาก

- บังคับ Multi-Factor Authentication (MFA) สำหรับระบบทุกระดับ โดยเฉพาะระบบที่มีข้อมูลส่วนบุคคล
- ใช้ Passwordless Authentication เมื่อเป็นไปได้ (FIDO2/WebAuthn) เพื่อความปลอดภัยสูงสุด
- กำหนด Password Policy ตาม NIST SP 800-63B: ความยาวขั้นต่ำ 8 ตัว ตรวจ Breached Password List
- ใช้ Rate Limiting และ Account Lockout Policy พร้อม CAPTCHA สำหรับการ Login ที่ผิดพลาดซ้ำ
- ผสาน Digital ID (ThaiID, DOPA-Digital ID) สำหรับการพิสูจน์ตัวตนประชาชน

2.8 A08 — Software & Data Integrity Failures

ครอบคลุม Insecure Deserialization, Unsigned Code, และการ Update ระบบ โดยไม่ตรวจสอบ Integrity เป็นประตูให้ผู้โจมตีแทรก Malicious Code เข้าไปในกระบวนการ Build หรือ Deploy

- ใช้ Code Signing สำหรับทุก Release Artifact ด้วย Sigstore หรือ GPG
- ตรวจสอบ Integrity ของ CI/CD Pipeline ด้วย SLSA Level 3 ขึ้นไป
- ใช้ Subresource Integrity (SRI) สำหรับ Third-party Libraries ทุกตัว
- ทำ Secure Deserialization: ตรวจสอบ Type และ Schema ก่อน Deserialize เสมอ

2.9 A09 — Security Logging & Monitoring Failures

การบันทึก Log ที่ไม่เพียงพอทำให้ไม่สามารถตรวจจับการโจมตีและสอบสวนเหตุการณ์ได้อย่างทันท่วงที ซึ่งเป็นข้อกำหนดบังคับ ตาม พ.ร.บ.ไซเบอร์ฯ มาตรา 45 สำหรับหน่วยงาน CII

- บันทึก Log ทุก Authentication Event (Success/Failure), Authorization Decision และ Data Access
- ส่ง Log ไปยัง Centralized SIEM (Elastic, Splunk, Wazuh) ทันที — ห้ามเก็บเฉพาะในเครื่อง Application
- ตั้ง Alert สำหรับ Anomaly: Login หลายครั้งผิดพลาด, Access นอกเวลาทำการ, Large Data Download
- เก็บ Log อย่างน้อย 90 วันตาม พ.ร.บ.ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์
- ทดสอบ Alert ด้วย Purple Team Exercise อย่างน้อยไตรมาสละ 1 ครั้ง

2.10 A10 — Mishandling of Exceptional Conditions (ใหม่)

หมวดหมู่ใหม่ใน OWASP Top 10:2025 ครอบคลุมการจัดการข้อผิดพลาด (Error Handling) ที่ไม่ปลอดภัย เช่น การแสดง Stack Trace ต่อผู้ใช้, การไม่ Handle Exception ทำให้ระบบ Crash หรือ Bypass Security Control ได้

- ใช้ Generic Error Messages ต่อผู้ใช้ — ห้ามแสดง Stack Trace, Database Error หรือ Internal Path
- บันทึก Error Detail ใน Secure Log เฉพาะ — แยกจาก User-facing Message
- ทดสอบ Error Handling ใน Pentest: ส่ง Malformed Input, Null Values, Boundary Conditions
- ใช้ Fail-Safe Default: เมื่อเกิด Error ให้ Deny Access เสมอ ไม่ใช่ Allow

บทที่ 3

สถาปัตยกรรม DevSecOps และ CI/CD Pipeline ที่ปลอดภัย

DevSecOps คือแนวปฏิบัติที่ฝัง Security เข้าไปในทุกขั้นตอนของ Software Development Life Cycle (SDLC) ตั้งแต่การออกแบบ พัฒนา ทดสอบ ไปจนถึงการ Deploy และ Operate แทนที่จะทำ Security ที่ปลายทางหรือเป็นขั้นตอนแยกต่างหาก ซึ่งช้ากว่าและแพงกว่า

3.1 หลักการ DevSecOps และ Shift-Left Security

Shift-Left Security หมายถึงการย้าย Security Testing และ Review มาทำให้เร็วขึ้น ("Left" ในไทม์ไลน์การพัฒนา) แทนที่จะรอทำก่อน Production ต้นทุนในการแก้ไข ช่องโหว่ที่พบในขั้น Design ถูกกว่าขั้น Production ถึง 30–100 เท่า

ขั้นตอน SDLC	Security Activity	เครื่องมือแนะนำ
Plan / Design	Threat Modeling, Security Requirements	STRIDE, PASTA, IriusRisk
Code	SAST, Code Review, Pre-commit Hooks	SonarQube, Semgrep, Bandit, ESLint
Build	SAST, SCA, Secret Scanning	Snyk, Trivy, GitLeaks, OWASP Dep-Check
Test	DAST, IAST, Pentest	OWASP ZAP, Burp Suite, Nuclei
Deploy	Container Scan, IaC Scan, Sign Artifact	Trivy, Checkov, Cosign
Operate	SIEM, RASP, WAF, Runtime Protection	Wazuh, Falco, ModSecurity
Monitor	Log Analysis, Anomaly Detection, Alerting	Elastic, Splunk, Prometheus

3.2 CI/CD Pipeline Security — SAST, DAST, SCA

Static Application Security Testing (SAST)

SAST วิเคราะห์ Source Code โดยไม่ต้อง Execute โปรแกรม ตรวจจับช่องโหว่ เช่น SQL Injection, XSS, Insecure Deserialization ได้ตั้งแต่ขั้น Code ก่อนที่จะ Build เป็น Artifact

- ฝัง SAST ใน Pre-commit Hooks เพื่อให้ Developer เห็นผลทันทีก่อน Push
- ใช้ Quality Gate ใน CI Pipeline: หาก Critical/High Vulnerability ห้าม Merge/Deploy
- เครื่องมือ Open-Source: Semgrep (หลายภาษา), Bandit (Python), SpotBugs (Java), ESLint (JS)
- เครื่องมือ Commercial: SonarQube, Checkmarx, Veracode

Dynamic Application Security Testing (DAST)

DAST ทดสอบแอปพลิเคชันที่กำลัง Run อยู่ โดยจำลองการโจมตีจริง เหมาะสำหรับตรวจจับช่องโหว่ที่ SAST มองไม่เห็น เช่น Business Logic Flaw และช่องโหว่ที่เกิดจาก Runtime Configuration

- ฝัง DAST ใน CI/CD โดยรัน Baseline Scan ทุก Build ใน Staging Environment
- รัน Full DAST Scan ก่อนทุก Production Release
- เครื่องมือ: OWASP ZAP (Open-source), Nuclei, Burp Suite Enterprise

Software Composition Analysis (SCA)

SCA ตรวจสอบ Dependencies ทั้งหมดที่โปรเจกต์ใช้ว่ามีช่องโหว่ที่รู้จัก (CVE) หรือ License ที่ไม่อนุญาตหรือไม่ ช่วยป้องกัน Supply Chain Attack ที่เพิ่มขึ้นอย่างรวดเร็วในปี 2025–2026

- สแกน Dependencies ทุกครั้งที่มีการ Build: npm, pip, Maven, Gradle, NuGet
- จัดทำ SBOM ในรูปแบบ CycloneDX หรือ SPDX ทุก Release เพื่อ Transparency
- ตั้ง Automated Update Policy: Critical CVE ต้อง Patch ภายใน 48 ชั่วโมง

3.3 Container Security และ Kubernetes Hardening

คอนเทนเนอร์และ Kubernetes กลายเป็นมาตรฐานการ Deploy สำหรับระบบภาครัฐสมัยใหม่ อย่างไรก็ตาม การตั้งค่าที่ไม่ถูกต้องเปิดพื้นที่โจมตีขนาดใหญ่

Image Security

- ใช้ Base Image ที่ Minimal: Distroless, Alpine หรือ UBI Minimal
- สแกน Container Image ด้วย Trivy หรือ Grype ก่อน Push ไปยัง Registry
- ใช้ Image Signing ด้วย Cosign และ Enforce Policy ด้วย Kyverno หรือ OPA Gatekeeper
- ห้ามรัน Container ด้วย root — ใช้ Non-root User เสมอ

Kubernetes Hardening

- เปิดใช้ RBAC และ Network Policies — Deny All Default, Allow Specific Flows
- ใช้ Pod Security Standards (Restricted Profile) สำหรับ Namespace ที่มีข้อมูลสำคัญ
- สแกน Kubernetes Configuration ด้วย kube-bench (CIS Benchmark) และ kubesec
- ใช้ Runtime Security: Falco สำหรับตรวจจับ Anomalous Syscall ใน Real-time
- จัดการ Secrets ด้วย HashiCorp Vault หรือ Kubernetes Sealed Secrets — ห้ามเก็บใน ConfigMap

3.4 Infrastructure as Code (IaC) Security

IaC ช่วยให้สามารถตรวจสอบ Infrastructure Configuration ด้วยเครื่องมือ Automated ได้เช่นเดียวกับ Source Code ช่วยป้องกัน Misconfiguration ที่เป็นสาเหตุของ A05 ใน OWASP Top 10

- ใช้ Checkov หรือ tfsec สแกน Terraform Code ก่อน Apply
- ตั้ง OPA (Open Policy Agent) Policy สำหรับ Enforce Security Rules ใน Terraform
- ใช้ Ansible Vault หรือ AWS Secrets Manager สำหรับจัดการ Credential ใน IaC
- ทำ Drift Detection: ตรวจสอบว่า Infrastructure จริงตรงกับ IaC Code เสมอ
- เก็บ IaC Code ใน Git Repository พร้อม Code Review Process เหมือน Application Code

3.5 Secret Management และ Zero Trust Architecture

Secret Management

Secret Management คือการจัดการ Credentials, API Keys, Certificates และ ข้อมูลลับอื่น ๆ อย่างปลอดภัย โดยไม่เก็บใน Source Code, Environment Variables แบบ Plaintext หรือ Log Files

- ใช้ HashiCorp Vault เป็น Central Secret Store พร้อม Dynamic Secrets สำหรับ Database
- ตั้ง Secret Rotation อัตโนมัติ: หมุน Database Password, API Key ทุก 30–90 วัน
- ใช้ GitLeaks หรือ TruffleHog สแกน Git History เพื่อหา Secret ที่ Commit ไปแล้ว
- บังคับ Short-lived Credentials ด้วย SPIFFE/SPIRE สำหรับ Service-to-Service Authentication

Zero Trust Architecture

Zero Trust ยึดหลัก "Never Trust, Always Verify" — ไม่มีการ Trust โดย Default แม้แต่ภายใน Internal Network ทุก Request ต้องพิสูจน์ตัวตนและได้รับ Authorization ก่อนเข้าถึง Resource ทุกครั้ง

- ใช้ Identity as the New Perimeter: ยืนยันตัวตนทุก Request ด้วย Short-lived Token
- ใช้ Micro-segmentation: แบ่ง Network ย่อยและจำกัด Lateral Movement
- Enforce Least Privilege: แต่ละ Service/User ได้เฉพาะสิทธิ์ที่จำเป็นขั้นต่ำ
- ใช้ Continuous Verification: ตรวจสอบ Device Health, Location และ Behavior ตลอดเวลา
- Log ทุก Access Decision พร้อม Context สำหรับ Audit Trail

บทที่ 4

การตรวจสอบ การติดตาม และการรายงานผล

การตรวจสอบและติดตามความปลอดภัยอย่างต่อเนื่องเป็นหัวใจของการรักษาความมั่นคงปลอดภัยไซเบอร์ระยะยาว บทนี้ครอบคลุมกระบวนการ Vulnerability Assessment, Penetration Testing, การตรวจสอบตามมาตรฐาน ASVS v5.0 การรายงานตามกฎหมายภาครัฐไทย และการวางแผน Incident Response ตาม NIST SP 800-61 Rev.3

4.1 Vulnerability Assessment & Penetration Testing

การทดสอบเจาะระบบที่มีประสิทธิภาพต้องอิงตามมาตรฐานที่ได้รับการยอมรับ 5 Methodologies หลักสำหรับปี 2025–2026 ได้แก่ OWASP WSTG, PTES, NIST SP 800-115, OSSTMM และ ISSAF โดย OWASP WSTG เน้น Web Application และ NIST เหมาะกับ หน่วยงานภาครัฐที่ต้องการ Compliance

Penetration Testing Lifecycle — 7 ขั้นตอนตาม PTES

- ขั้นที่ 1 Pre-engagement: กำหนดขอบเขต (Scope), Rules of Engagement, กรอบเวลา และ Legal Authorization
- ขั้นที่ 2 Intelligence Gathering: รวบรวมข้อมูลเป้าหมาย ทั้ง Passive (OSINT) และ Active Reconnaissance
- ขั้นที่ 3 Threat Modeling: วิเคราะห์ Assets, Attack Surface และจัดลำดับความเสี่ยงตาม OWASP Top 10
- ขั้นที่ 4 Vulnerability Analysis: สแกนและระบุจุดอ่อนด้วย Automated Tools + Manual Testing (3–7 วัน)
- ขั้นที่ 5 Exploitation: ทดสอบ Exploit จุดอ่อนที่พบเพื่อยืนยันผลกระทบจริง
- ขั้นที่ 6 Post-Exploitation: ประเมินขอบเขตความเสียหาย, Lateral Movement และ Data Exfiltration Potential
- ขั้นที่ 7 Reporting: จัดทำรายงานรวม Executive Summary, Findings by Severity, Remediation Recommendations

Hybrid Solution: เครื่องมือแนะนำ

ประเภท	Open-Source	Commercial	แนวทาง Hybrid
Automated VA	OpenVAS, Nuclei	Nessus, Qualys	OpenVAS รายสัปดาห์ + Nessus รายไตรมาส

Web App Scan	OWASP ZAP	Burp Suite Pro	ZAP ใน CI/CD + Burp Suite Full Scan ก่อน Go-live
Network Scan	Nmap, Masscan	Rapid7 InsightVM	Nmap Baseline + Rapid7 Full Assessment
Code Analysis	Semgrep, Bandit	Checkmarx, Snyk	Semgrep ใน Pre-commit + Checkmarx ใน CI

4.2 ASVS v5.0 Verification Playbook

ASVS v5.0 มีการเปลี่ยนแปลงเชิงหลักการสำคัญ: ทุกบทเริ่มต้นด้วยข้อกำหนด Documentation เพื่อเสริม Accountability และเชื่อมโยง Design กับ Implementation และเน้น Goal-Oriented Requirements มากกว่า Technical Prescriptions

Playbook การตรวจสอบตาม ASVS 5.0

- ขั้นที่ 1 — กำหนด Verification Level: L1 (Quick), L2 (Standard — แนะนำ), L3 (High Assurance สำหรับ CII)
- ขั้นที่ 2 — Export Checklist จาก OWASP GitHub Repository ตาม Level และ Chapter ที่เลือก
- ขั้นที่ 3 — Hybrid Assessment: ผสม SAST/DAST/SCA กับ Manual Code Review และ Document Review
- ขั้นที่ 4 — บันทึก Documented Security Decisions ทุก Control พร้อมหลักฐาน
- ขั้นที่ 5 — ออก Verification Report อ้างอิงรูปแบบ v5.0.0-<Chapter>.<Section>.<Requirement>

4.3 ระบบรายงานภาครัฐ — แบบฟอร์ม ค๑/ค๒

พ.ร.บ. การรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562 กำหนดให้ทุกหน่วยงานรัฐต้องปฏิบัติตามประมวลแนวทางปฏิบัติและกรอบมาตรฐานตามมาตรา 45 ปัจจุบันมีหน่วยงาน CII 54 หน่วยงานที่ต้องปฏิบัติตาม

มาตรฐานความปลอดภัยเว็บไซต์ 2025 ของ สกมช.

ในเดือนกันยายน 2568 สกมช. ประกาศมาตรฐานความปลอดภัยเว็บไซต์ 2025 ซึ่งบังคับใช้กับทุกหน่วยงานรัฐ การประเมินใช้หลัก "High Water Mark" — หากเว็บไซต์ถูกจัดว่าเป็น "ความเสี่ยงสูง" ในด้านใดด้านหนึ่งจาก 4 ด้าน ระดับความเสี่ยงโดยรวมจะถูกยกเป็นระดับสูงโดยอัตโนมัติ

ด้านความเสี่ยง	ตัวอย่างระบบที่เกี่ยวข้อง
ทรัพย์สินทางการเงิน	ระบบจัดเก็บภาษี, ระบบชำระเงินภาครัฐ
การดำเนินงาน	ระบบทะเบียนราษฎร์, ระบบออกใบอนุญาต

ความปลอดภัยสาธารณะ	ระบบตำรวจ, ระบบสาธารณสุขฉุกเฉิน
ความมั่นคงของชาติ	ระบบกลาโหม, ระบบข่าวกรอง

Compliance Checklist สำหรับหน่วยงานภาครัฐ

- จัดทำรายชื่อผู้บริหารและเจ้าหน้าที่ปฏิบัติการพร้อมช่องทางติดต่อฉุกเฉิน
- จัดทำแนวทางปฏิบัติด้านไซเบอร์: แผนตรวจสอบ + ประเมินความเสี่ยง + IRP
- จัดทำกรอบมาตรฐานด้านไซเบอร์ 5 มาตรการ (ระบุ, ป้องกัน, ตรวจจับ, ตอบสนอง, กู้คืน)
- ดำเนินการ Self-Assessment ประจำปีตามแบบฟอร์ม ค๑/ค๒
- ตั้งกลไกรายงานเหตุการณ์ภายใน 24 ชั่วโมงสำหรับหน่วยงาน CII
- อัปเดตรายชื่อผู้รับผิดชอบภายใน 15 วันหลังมีการเปลี่ยนแปลง

4.4 Incident Response ตาม NIST SP 800-61 Rev.3

NIST SP 800-61 Revision 3 เผยแพร่ในเดือนเมษายน 2568 ปรับ Incident Response ให้สอดคล้องกับ 6 Functions ของ NIST CSF 2.0 กระบวนการเป็นวงจร 4 ขั้นตอน ไม่ใช่ Linear Activity

ขั้นตอน	กิจกรรมหลัก	เครื่องมือ/ผลลัพธ์
1. Preparation	กำหนดนโยบาย บทบาท ฝึกอบรม Deploy เครื่องมือ Monitoring	IRP Document, Runbook, SIEM Setup
2. Detection & Analysis	เฝ้าระวัง Logs, Alerts และ Threat Intel อย่างต่อเนื่อง	Alert Triage, Severity Classification
3. Containment, Eradication & Recovery	ควบคุมผลกระทบ กำจัดภัยคุกคาม กู้คืนระบบ	Network Isolation, Clean Reinstall, Restore
4. Post-Incident Activity	Root Cause Analysis และปรับปรุงแผน	PIR Report, Updated Playbooks, Lessons Learned

ตัวอย่าง SOAR Playbook สำหรับ Ransomware

- Trigger: EDR ตรวจจับ File Encryption ผิดปกติหรือ Ransom Note ถูกสร้าง
- Auto-action 1: Isolate Host จาก Network ทันทีภายใน 60 วินาที
- Auto-action 2: Snapshot VM ปัจจุบันเพื่อ Forensic Evidence
- Auto-action 3: แจ้ง Incident Response Team ผ่าน PagerDuty/Teams/Line
- Manual-action: SOC Analyst รับการแจ้งเตือน ยืนยัน False Positive/True Positive
- Eradication: ค้นหา Patient Zero, ล้าง Malware, ตรวจสอบ Lateral Movement
- Recovery: Restore จาก Clean Backup, Validate ความสมบูรณ์ข้อมูล, Reconnect Network

บทที่ 5

ภัยคุกคามอุบัติใหม่ในยุค AI และการรับมือ

ปี 2025–2026 เป็นจุดเปลี่ยนที่ผู้โจมตีนำ Agentic AI มาใช้ในการโจมตีแบบอัตโนมัติ ควบคู่กับการถือกำเนิดของ Post-Quantum Computing ที่คุกคามการเข้ารหัสแบบเดิม หน่วยงานภาครัฐต้องเตรียมรับมือกับภัยคุกคามระดับใหม่เหล่านี้อย่างจริงจัง

5.1 Agentic AI & Automated Attacks

จากผลสำรวจของ Dark Reading พบว่า 48% ของผู้เชี่ยวชาญด้านความปลอดภัย ระบุว่า Agentic AI เป็น Attack Vector อันดับหนึ่งในปี 2569 Flashpoint รายงานว่าการกล่าวถึง AI ในแหล่ง Underground เพิ่มขึ้น 1,500% ภายในเดือนเดียว (จาก 362,000 ครั้ง เป็นกว่า 6 ล้านครั้ง)

Architecture Layer — การออกแบบป้องกัน

- ติดตั้ง Human-in-the-Loop (HITL) Checkpoints สำหรับการกระทำที่มีผลกระทบสูง เช่น การโอนเงิน การลบข้อมูล หรือการเปลี่ยน Access Control Policy
- ใช้ Identity Management Framework เฉพาะสำหรับ Non-human Identities (NHI) แยกจาก Human Identity เพื่อควบคุม AI Agent
- สร้าง Immutable Audit Trails สำหรับ Agent Long-term Storage เพื่อป้องกัน Memory Poisoning
- จำกัด Tool Access ของ AI Agent ตามหลัก Least Privilege — Agent ควรทำได้เฉพาะที่จำเป็น

Development Layer

- ทำ Supply Chain Scanning ก่อน Deploy AI Agent ทุกครั้ง
- จัดทำ SBOM สำหรับทุก AI Agent Component และตรวจสอบ Model Integrity
- พัฒนา Guardrails: Input Validation, Prompt Injection Detection และ Output Filtering
- ทดสอบ AI Agent ด้วย Red Team Exercise เฉพาะทาง ครอบคลุม Jailbreak และ Indirect Prompt Injection

Operations Layer

- ปรับปรุง Incident Response Playbooks ให้รองรับ Agent Compromise ที่ทำงานเร็วกว่ามนุษย์
- Deploy AI-powered DRP เพื่อเปลี่ยนจาก Passive Monitor เป็น Proactive Defense ตลอด 24/7
- ตั้ง Rate Limiting และ Quota สำหรับ AI Agent เพื่อป้องกัน Resource Exhaustion

5.2 AI-driven Threat Detection — SIEM/SOAR/XDR

การรับมือภัยคุกคามสมัยใหม่ต้องอาศัยแนวทางที่บูรณาการ SIEM, SOAR และ EDR เข้าเป็นแพลตฟอร์มเดียว โดยใช้ AI/ML เป็นแกนกลางในการตรวจจับ วิเคราะห์ และตอบสนองต่อภัยคุกคามแบบ Real-time

องค์ประกอบ	Open-Source	Commercial	Hybrid Approach
SIEM	Elastic SIEM, Wazuh	Splunk, IBM QRadar	Elastic SIEM + Commercial Threat Intel
SOAR	TheHive, Shuffle	Palo Alto XSOAR	Open-source Orchestration + Commercial Playbooks
EDR	Velociraptor, OSSEC	CrowdStrike, SentinelOne	Open-source Endpoint + Commercial AI Engine
Threat Intel	MISP, OpenCTI	Recorded Future	Community Feeds + Premium Intelligence
XDR	Elastic XDR	Microsoft Sentinel	Sentinel สำหรับ Cloud + Wazuh สำหรับ On-prem

การตั้งค่า AI-powered Detection Engineering

- ใช้ User Behavior Analytics (UBA) สร้าง Behavioral Baselines สำหรับผู้ใช้และระบบ
- ติดตั้ง Agentic AI Triage สำหรับ Investigation อัตโนมัติรวมถึง Low-fidelity Alerts
- สร้าง AI Feedback Loop ที่ทีม SOC ปรับแต่ง Triage Behavior ตาม Environmental Context
- ใช้ Predictive Policy Adjustments — AI ร่าง Firewall Rules แบบ Dynamic ตาม Real-time Threat Intel

5.3 Post-Quantum Cryptography — Migration Playbook

NIST ได้เผยแพร่มาตรฐาน PQC สามฉบับในเดือนสิงหาคม 2567 ภัยคุกคาม "Harvest Now, Decrypt Later" (HNDL) กำลังเกิดขึ้นจริง หน่วยงานระดับรัฐกำลังเก็บรวบรวมข้อมูลที่เข้ารหัสไว้รอวันที่ Quantum Computer สามารถถอดรหัสได้ NSM 10 กำหนดเป้าหมายปี 2578 สำหรับการนำ PQC มาใช้ทั่วระบบ

มาตรฐาน	Algorithm	ทดแทน	การใช้งาน
FIPS 203	ML-KEM (Module-Lattice Key-Encapsulation)	RSA, ECDH	Key Exchange / Encryption
FIPS 204	ML-DSA (Module-Lattice Digital Signature)	RSA, ECDSA	Digital Signatures หลัก

FIPS 205	SLH-DSA (Stateless Hash-based Signature)	RSA, ECDSA	Hash-based Signatures (Backup)

Playbook 5 ขั้นตอนสำหรับ Migration

- ขั้นที่ 1 — Crypto Inventory: ระบุ Algorithm และ Protocol ทั้งหมดในระบบ (TLS Version, Key Size, Hash Algorithm)
- ขั้นที่ 2 — Risk Prioritization: จัดลำดับ Data ที่ต้องป้องกันนานเกิน 5–10 ปี (Long-lived Data)
- ขั้นที่ 3 — Hybrid Mode: ใช้ Classic + PQC Algorithm คู่กันในช่วง Transition เพื่อ Backward Compatibility
- ขั้นที่ 4 — Pilot Migration: เริ่มจากระบบ Non-critical ก่อน ทดสอบ Performance Impact
- ขั้นที่ 5 — Full Migration: ย้ายระบบ Critical ทั้งหมดเป็น PQC ตามเป้าหมาย พร้อม Audit Trail

5.4 LLM Security — OWASP Top 10 for LLM 2025

OWASP ออก Top 10 for LLM Applications 2025 เพื่อรับมือกับการนำ Generative AI มาใช้ในระบบภาครัฐ โดยเฉพาะ AI Chatbot บริการประชาชน, ระบบวิเคราะห์เอกสาร และ Agentic AI ที่ทำงานแทนมนุษย์

ช่องโหว่	คำอธิบาย	มาตรการป้องกัน
LLM01: Prompt Injection	ผู้โจมตีฝัง Malicious Instructions ใน Prompt	Input Validation, Prompt Firewall, Sandboxing
LLM02: Insecure Output Handling	LLM Output ถูกนำไปใช้โดยไม่ Sanitize	Output Validation, Escaping ก่อนใช้งาน
LLM06: Excessive Agency	LLM มีสิทธิ์เกินจำเป็นในการดำเนินการ	HITL, Least Privilege, Action Approval
LLM08: Vector & Embedding Weaknesses	RAG System ถูก Poison ด้วยข้อมูลมีพิษ	Data Provenance, Embedding Validation
LLM09: Misinformation	LLM Hallucinate ให้ข้อมูลผิดพลาด	Grounding, Retrieval Augmentation, Fact-check

5.5 MLSecOps Pipeline

MLSecOps คือการขยาย DevSecOps เพื่อครอบคลุม Machine Learning Life Cycle ตั้งแต่การเก็บรวบรวมข้อมูล Training จนถึงการ Monitor Model ใน Production โดยเน้นความปลอดภัยของทั้ง Data, Model และ Infrastructure

- Data Security: เข้ารหัส Training Data at Rest และ in Transit, ทำ Data Lineage Tracking

• Model Security: ทำ Adversarial Robustness Testing, ป้องกัน Model Inversion Attack

• Training Security: Secure ML Compute Environment, ป้องกัน Poisoning Attack บน Training Data

• Deployment Security: Container Hardening สำหรับ Model Serving, API Rate Limiting

• Monitoring: ตรวจจับ Model Drift, Data Drift และ Anomalous Inference Patterns

• Privacy: ใช้ Federated Learning หรือ Differential Privacy สำหรับ Sensitive Data

บทที่ 6

อธิปไตยข้อมูลภาครัฐและระบบเอกสารดิจิทัลอัจฉริยะ

ในยุคที่ข้อมูลราชการคือทรัพย์สินเชิงยุทธศาสตร์ของชาติ ความเสี่ยงจากการพึ่งพา ระบบ SaaS ของบริษัทเทคโนโลยีต่างชาติกลายเป็นประเด็นระดับความมั่นคง กฎหมาย US CLOUD Act ปี 2018 ให้อำนาจรัฐบาลสหรัฐฯ ในการเข้าถึงข้อมูล อิเล็กทรอนิกส์ที่จัดเก็บโดยบริษัทในเขตอำนาจศาลสหรัฐฯ โดยไม่คำนึงว่า ข้อมูลจะจัดเก็บอยู่ที่ใดในโลก

6.1 Data Sovereignty Framework ของไทย

สำนักงานพัฒนารัฐบาลดิจิทัล (DGA) ได้ออกแนวปฏิบัติ "Go Cloud First" พร้อมกรอบการจำแนกข้อมูลภาครัฐ 3 ระดับ ดังนี้

ระดับข้อมูล	คำจำกัดความ	ข้อกำหนดการจัดเก็บ
ข้อมูลทั่วไป	ข้อมูลสาธารณะที่เปิดเผยได้	Public Cloud หรือ Private Cloud ใดก็ได้
ข้อมูลที่ต้องปกป้อง	ข้อมูลส่วนบุคคล, ข้อมูลธุรกิจ	Cloud ที่มี Data Residency ในไทย, เข้ารหัส
ข้อมูลที่ต้องปกป้องอย่างเข้มงวด	ข้อมูลความมั่นคงของชาติ, ข้อมูล CII	Sovereign Cloud หรือ On-premise ในไทยเท่านั้น

6.2 Collabora Online — Server-Side Rendering Architecture

Collabora Online (COOL) เป็นชุดโปรแกรมสำนักงานออนไลน์โอเพนซอร์ส พัฒนาบนพื้นฐาน LibreOffice โดยยึดหลักการสำคัญว่าเอกสารจะไม่ออกจาก เซิร์ฟเวอร์ตลอดทั้งเซสชัน ผู้ใช้ได้รับเพียง "Pixel Tiles" ไม่ใช่ไฟล์เอกสารจริง

กระบวนการทำงาน

- ขั้นที่ 1: ผู้ใช้เปิดเอกสารผ่านเว็บเบราว์เซอร์ เซิร์ฟเวอร์ทำการ Render เอกสารฝั่งเซิร์ฟเวอร์
- ขั้นที่ 2: ส่งเฉพาะ "Tiles" (ชิ้นภาพ) ของส่วนที่ผู้ใช้มองเห็น ไม่ใช่ตัวเอกสารจริง
- ขั้นที่ 3: การแก้ไขของผู้ใช้ถูกส่งกลับไปยังเซิร์ฟเวอร์เพื่อประมวลผลและ Render ใหม่
- ผลลัพธ์ด้านความปลอดภัย: เบราว์เซอร์ได้รับเพียง Pixel เท่านั้น ไม่สามารถดึงเอกสารต้นฉบับออกมาได้

ข้อดีของ Collabora Online

- Single-container Docker: ปฏิบัติตามหลัก Single Concern ออกแบบ Stateless รองรับ Kubernetes Cluster
- ISO 9001 และ ISO 27001 Certified: ยืนยันมาตรฐานสูงสุดด้านกระบวนการธุรกิจและความปลอดภัย

• WOPI Protocol: เชื่อมต่อกับระบบจัดเก็บไฟล์ใดก็ได้ที่รองรับ WOPI (Nextcloud, SharePoint)

• Chroot Jail Sandboxing: แต่ละเอกสารประมวลผลใน Isolated Process ป้องกัน Malware Propagation

6.3 ONLYOFFICE DocSpace — HTML5 Canvas Architecture

ONLYOFFICE ใช้แนวทางที่แตกต่าง — แปลงเอกสารเป็น JSON บนเซิร์ฟเวอร์ จากนั้น Stream ไปยังเบราว์เซอร์ซึ่งทำงานเป็นโปรแกรมแก้ไขเต็มรูปแบบ ด้วย HTML5 Canvas มีผู้ใช้งานทั่วโลกกว่า 15 ล้านคน รองรับไฟล์ 50+ รูปแบบ

ระบบ Room-Based Management

• Collaboration Rooms: ทำงานร่วมกันแบบ Real-time หลายคนพร้อมกัน

• Public Rooms: แชร์เอกสารกับบุคคลภายนอกโดยไม่ต้องสร้างบัญชี

• Form Filling Rooms: ระบบกรอกแบบฟอร์มออนไลน์ที่ปลอดภัย

• Virtual Data Rooms (VDR): ห้องข้อมูลสำหรับเอกสารลับสูง

• Private Rooms: เข้ารหัส End-to-End สำหรับเอกสารที่ต้องการความลับสูงสุด

6.4 Federated Cloud สำหรับภาครัฐ

Federated Cloud ช่วยให้หน่วยงานภาครัฐแต่ละแห่งสามารถติดตั้งระบบของตนเองในศูนย์ข้อมูลที่ควบคุมเอง แต่ยังสามารถทำงานร่วมกันข้ามหน่วยงานได้อย่างไร้รอยต่อ แต่ละหน่วยงานยังคงควบคุมข้อมูลของตนเอง 100%

กรณีศึกษาระดับสากล

• โครงการ SURF ของเนเธอร์แลนด์: ให้บริการผู้ใช้กว่า 100,000 คน จาก 59 สถาบันการศึกษา ด้วย Nextcloud + Collabora Online

• โครงการ openDesk ของรัฐบาลกลางเยอรมนี: ย้ายจาก Microsoft 365 สู่ระบบอธิปไตยดิจิทัล Open-source ทั้งหมด

• ข้อเสนอสำหรับไทย: จัดตั้ง GovCloud กลางภายใต้การกำกับของ ETDA/DGA โดยใช้ Sovereign Cloud Infrastructure

6.5 Government-Grade Security สำหรับเอกสารดิจิทัล

ด้าน	Collabora Online	ONLYOFFICE
หลักการ Docker	คอนเทนเนอร์เดียว Stateless (✓)	5+ บริการในคอนเทนเนอร์เดียว (✗)

การอัปเดต	Pull/Restart ง่าย (✓)	ต้อง Migration ซับซ้อน (✗)
การ Scale	Kubernetes-native (✓)	ต้องจัดการ State ภายใน (✗)
Fidelity กับ MS Office	ดี (LibreOffice Engine)	ดีมาก (OOXML Native Format) (✓)
SELinux Support	ไม่ต้องปิด SELinux (✓)	แนะนำให้ปิดบน RPM distros (✗)
ISO 27001 Certified	มี (✓)	ไม่ระบุ

สำหรับหน่วยงานที่มีข้อมูลที่ต้องปกป้องอย่างเข้มงวด แนะนำ Collabora Online เนื่องจากสถาปัตยกรรม Server-Side Rendering ที่ปลอดภัยกว่าและ ISO 27001 Certified สำหรับหน่วยงานที่แลกเปลี่ยนเอกสารกับองค์กรที่ใช้ Microsoft Office เป็นหลัก แนะนำ ONLYOFFICE เนื่องจาก OOXML Native Format ที่แม่นยำกว่า

บทสรุป

คู่มือฉบับนี้ได้นำเสนอสถาปัตยกรรมความมั่นคงปลอดภัยไซเบอร์แบบครบวงจรสำหรับหน่วยงานภาครัฐไทย ตั้งแต่รากฐานมาตรฐานสากล OWASP, NIST และ ISO ไปจนถึงภัยคุกคามอุบัติใหม่ในยุค AI และการสร้างอธิปไตยข้อมูลของชาติ หัวใจสำคัญของคู่มือนี้สรุปได้ใน 5 ประเด็นหลัก

สรุปประเด็นสำคัญ 5 ข้อ

1. Security ต้องเริ่มจากการออกแบบ ไม่ใช่ปลายทาง

Shift-Left Security และ Threat Modeling ตั้งแต่ขั้น Design ช่วยลดต้นทุน การแก้ไขได้ 30–100 เท่าเมื่อเทียบกับการค้นพบปัญหาใน Production OWASP Top 10:2025 ครอบคลุมทั้ง Broken Access Control, Cryptographic Failures และ Insecure Design ที่ต้องแก้ที่ระดับสถาปัตยกรรม

2. DevSecOps คือมาตรฐานใหม่ของการพัฒนาซอฟต์แวร์ภาครัฐ

CI/CD Pipeline ที่รวม SAST, DAST, SCA, Container Security และ IaC Scanning เป็น Automated Gate ช่วยให้หน่วยงานภาครัฐสามารถ Deploy ได้อย่างรวดเร็ว โดยไม่ลดทอนความปลอดภัย ต้องกำหนดใน TOR/RFP ทุกโครงการใหม่

3. การตรวจสอบและรายงานเป็นข้อบังคับทางกฎหมาย

พ.ร.บ.ไซเบอร์ฯ กำหนดให้หน่วยงาน CII ต้องรายงานเหตุการณ์ภายใน 24 ชั่วโมง จัดทำแบบฟอร์ม ค๑/ค๒ ประจำปี และดำเนินการตาม NIST SP 800-61 Rev.3 การไม่ปฏิบัติตามมีโทษทางกฎหมาย

4. ภัยคุกคาม AI และ Post-Quantum ต้องเตรียมรับมือทันที

Agentic AI Attacks, Post-Quantum Cryptography Migration (FIPS 203/204/205) และ LLM Security เป็นภัยคุกคามที่ต้องดำเนินการวันนี้ ไม่ใช่อนาคต ข้อมูลที่เข้ารหัสวันนี้อาจถูก Harvest Now, Decrypt Later ได้

5. อธิปไตยข้อมูลคือประเด็นความมั่นคงของชาติ

การพึ่งพา SaaS ต่างชาติโดยไม่มีแผน Sovereign Cloud สำหรับข้อมูลที่ต้องปกป้องอย่างเข้มงวดเป็นความเสี่ยงทางกฎหมายและความมั่นคง ระบบ Self-hosted เช่น Collabora Online และ ONLYOFFICE DocSpace เป็นทางเลือกที่มีความพร้อม ระดับ Production สำหรับหน่วยงานภาครัฐไทย

แผนปฏิบัติการที่แนะนำ

ระยะเวลา	กิจกรรมที่แนะนำ	ผลลัพธ์ที่คาดหวัง
0–3 เดือน (Quick Win)	ทำ Pentest ระบบสำคัญ, ตั้ง SIEM/Wazuh, บังคับ MFA	ลดพื้นที่โจมตีทันที
3–6 เดือน	ฝัง SAST/DAST ใน CI/CD, จัดทำ IRP, ทำ ASVS L2 Assessment	DevSecOps Pipeline พื้นฐาน
6–12 เดือน	ทำ Threat Modeling ทุกระบบใหม่, ตั้ง Secret Management, อัปเดต PDPA Controls	Security by Design
1–2 ปี	เริ่ม PQC Migration Pilot, พัฒนา AI Guardrails, ประเมิน Sovereign Cloud	Future-proof Architecture
2–3 ปี	PQC Full Migration, Federated Government Cloud, ISO 27001 Certification	อธิปไตยข้อมูลสมบูรณ์

คำแนะนำสำหรับผู้บริหาร

ความมั่นคงปลอดภัยไซเบอร์ไม่ใช่ค่าใช้จ่าย แต่คือการลงทุนในความยั่งยืนของ การให้บริการภาครัฐ ต้นทุนเฉลี่ยของการถูก Data Breach ในภาครัฐอยู่ที่ ประมาณ 2–5 ล้านดอลลาร์สหรัฐ ยังไม่รวมความเสียหายต่อความน่าเชื่อถือ การลงทุนในมาตรการป้องกันที่ถูกต้องคือการประกันความต่อเนื่องของบริการ และความไว้วางใจของประชาชนที่คุ้มค่ากว่าเสมอ